

Crypto-Agility in Post-Quantum Cloud Infrastructure: Deployment Challenges and Architectural Trade-offs

Student: *Charbel Mattar*
Supervisor: *Rizkallah Bachour*

Department of Computer Science, Lebanese International University
May 2026

Abstract

Fault-tolerant quantum computing will render RSA and ECC insecure by reducing their underlying mathematical hard problems to polynomial-time computation via Shor's algorithm. The urgency of migrating to NIST post-quantum cryptography (PQC) standards is compounded by Harvest Now, Decrypt Later (HNDL) attacks, in which adversaries archive encrypted traffic today for quantum decryption once capable hardware matures. A uniform substitution of classical primitives with lattice-based alternatives, however, creates deployment friction that existing migration guidance does not fully resolve. ML-KEM-1024 encapsulation keys (1,568 bytes) and ML-DSA signatures (2,420 - 4,627 bytes) can exceed the standard 1,500-byte Ethernet Maximum Transmission Unit (MTU) when combined with protocol framing overhead, and ML-DSA payloads strain the volatile memory of many deployed Hardware Security Modules (HSMs). These constraints impose measurable costs on handshake latency, packet fragmentation risk, and Zero Trust Architecture (ZTA) verification cycles.

This paper makes three contributions. First, it characterizes the operational tension between lattice-based PQC primitives and existing cloud network constraints, drawing on FIPS 203, FIPS 204, FIPS 205, and current IETF transport-layer work. Second, it identifies specific failure modes this tension introduces for Zero Trust identity infrastructure. Third, it proposes a Tiered Cryptographic Agility Model: a workload-stratified migration framework that applies dual-wrap hybrid encryption to cold storage, symmetric key ratcheting to latency-sensitive microservices, and PQC-signed software gateway tokens to bridge the hardware adoption gap. The framework is positioned against the NIST SP 800-207 Zero Trust reference architecture and the deployment-security guidance of NIST SP 800-227.

1. Introduction

Global cloud security relies on RSA and ECC: public-key standards whose security depends on the computational difficulty of integer factorization and discrete logarithm problems [1, 2, 3]. These problems are resistant to classical computation only in an exponential-time sense. Shor's algorithm, executable on a fault-tolerant quantum computer, reduces both to polynomial time [5], eliminating the mathematical foundation on which RSA and ECC rest.

The threat is not purely prospective. HNDL attacks allow adversaries to collect and store ciphertext today with the intention of decrypting it once quantum hardware matures [6]. For data with long confidentiality horizons, such as medical records, financial contracts, and compliance archives, HNDL exposure is a present operational risk. NIST has responded by standardizing ML-KEM (FIPS 203), ML-DSA (FIPS 204), and SLH-DSA (FIPS 205) as quantum-resistant primitives [12, 13, 14], and both NIST and IETF are publishing migration and integration guidance [7, 10, 15, 16].

The deployment gap, however, has received insufficient systematic attention. Cloud architectures built on static protocol stacks and legacy hardware trust anchors cannot accommodate larger cryptographic primitives without operational consequences. Addressing this gap is the central purpose of this paper.

Research question: How can cloud architectures achieve quantum-resistant cryptographic agility without incurring prohibitive network performance penalties or disrupting Zero Trust verification workflows?

Contributions: This paper:

1. Characterizes the network-layer and hardware constraints that complicate a uniform PQC migration in cloud environments, with reference to current NIST and IETF standards.
2. Identifies the specific failure modes these constraints impose on Zero Trust identity infrastructure.
3. Proposes a Tiered Cryptographic Agility Model that stratifies workloads by latency sensitivity and HNLD exposure, assigning distinct cryptographic strategies to each tier.

Scope: This is a conceptual and architectural analysis. It synthesizes published standards, draft specifications, and peer-reviewed literature to identify deployment constraints and propose a structured migration framework. It does not present empirical benchmarks; quantifying PQC overhead in specific production environments is an identified direction for future work.

1.1 Problem Statement

Contemporary cloud infrastructure is operationally rigid: protocol stacks, hardware trust roots, and HSMs were designed around compact classical key material. Substituting PQC primitives into these environments introduces tension between security and operational performance in the form of an integration gap that is not resolved by algorithm selection alone. Bridging it requires architectural accommodation at the network, hardware, and identity layers simultaneously.

1.2 Technical Background & Terminology

The following terms are used with specific meanings throughout this paper.

- **Asymmetric Foundations:** Public-key primitives such as RSA and ECC derive security from the computational asymmetry of their underlying mathematical problems: easy to compute in one direction, computationally infeasible to reverse without the private key under classical computation [1, 2, 3].
- **Shor's Algorithm:** A quantum algorithm capable of solving integer factorization and discrete logarithm problems in polynomial time, neutralizing the hardness assumptions on which RSA and ECC depend [5].
- **Crypto-Agility:** An architectural property whereby cryptographic components are decoupled from application logic, enabling algorithm replacement via configuration or policy rather than code-level refactoring [7].

- **Key Encapsulation Mechanism (KEM):** A cryptographic primitive that allows a sender to generate and securely transmit a symmetric key to a recipient using the recipient's public key. ML-KEM (FIPS 203) is the NIST-standardized post-quantum KEM [12].

2. Literature Review

The transition to quantum-resistant cloud environments requires re-evaluating both cryptographic protocols and the infrastructure supporting them. The following review covers three intersecting bodies of work: the conceptual and operational definition of crypto-agility; the contrast between application-layer PQC progress and hardware rigidity; and the network and temporal constraints shaping migration strategy.

2.1 Defining and Operationalizing Crypto-Agility

Until recently, cryptographic agility lacked a stable formal definition, which complicated systematic implementation [7]. NIST's 2025 Cybersecurity White Paper 39 frames agility as a strategic, algorithm-agnostic capability: systems must support diverse cryptographic methods across multiple protocols so that no single algorithm compromise forces a full architectural redesign [7]. Current NIST guidance emphasizes hybrid schemes during the transition period (pairing traditional public-key mechanisms with post-quantum alternatives such as ML-KEM), so that security is preserved as long as at least one component remains uncompromised [4, 7].

The literature also highlights the gap between policy intent and implementation readiness. Agility is frequently treated as a software property, but the standards community increasingly recognizes that hardware-anchored trust roots impose constraints that software flexibility cannot fully compensate [7, 9].

2.2 Application-Layer Integration vs. Infrastructure Rigidity

PQC integration has advanced most rapidly at the application layer. Hybrid key management models (generating AES-256 symmetric keys alongside ML-KEM for encapsulation and ML-DSA for authentication) have been shown to be technically viable in SaaS environments [8]. Treating PQC primitives as modular components enables incremental migration and reduces the risk of a disruptive protocol swap [7].

Application-layer progress, however, does not automatically extend to hardware. HSMs and hardware-anchored trust roots are significantly more constrained than software systems in terms of memory, processing capacity, and update cycles [7, 9]. ML-DSA signatures range from 2,420 to 4,627 bytes across the three standardized parameter sets [13]; many currently deployed HSMs lack the volatile memory to process or transmit payloads of this size without hardware modification. This hardware lag creates a persistent gap between what software-defined systems can implement and what physical trust anchors can support.

A distinct implementation concern applies across both layers. ML-KEM implementations remain vulnerable to classical side-channel attacks, including power analysis and electromagnetic leakage [11]. Quantum resistance at the algorithm level does not eliminate these physical attack surfaces; hardware hardening and thorough implementation review remain necessary components of a complete security posture.

2.3 Network Constraints and Temporal Risks

PQC primitives introduce network-layer constraints that existing protocol stacks were not designed to accommodate. The primary constraint is key and signature size. ML-KEM-768 encapsulation keys are 1,184 bytes and ML-KEM-1024 encapsulation keys are 1,568 bytes [12]; ML-DSA signatures range from 2,420 bytes (ML-DSA-44) to 4,627 bytes (ML-DSA-87) [13]. Whether any of these sizes cause fragmentation depends on the full protocol stack, including TLS record overhead, TCP/IP headers, and path MTU, not on primitive size in isolation. RFC 894 defines 1,500 octets as the standard Ethernet MTU [17]; under that constraint, ML-KEM-768 keys fall within it, while ML-KEM-1024 keys and all ML-DSA signatures can exceed it once protocol framing is accounted for.

Although still under active standardization, the current IETF's draft standard for ML-KEM in TLS 1.3 addresses this directly, defining both standalone ML-KEM key establishment and hybrid constructions that pair PQC with classical key exchange [10]. This design reflects the standards community's view that the transition period requires accommodating both larger primitive sizes and legacy infrastructure through managed mechanisms (record splitting, path MTU discovery, and hybrid key exchange) rather than an all-or-nothing protocol cut-over.

The temporal dimension of these constraints is driven by HNDL risk. Classical encryption provides no protection against an adversary who archives ciphertext today for quantum decryption later [6]. This risk is particularly acute for Zero Trust Architectures, which rely on continuous identity verification: if the underlying authentication tokens are not quantum-resistant, the identity layer becomes a retroactive liability. Hardware adoption lag (the multi-year gap between software standardization and widespread availability of PQC-capable FIDO2 tokens and HSMs) amplifies this exposure and motivates the adaptive hybrid designs described in the following section [7, 8, 9].

3. Analysis & Discussion

Moving post-quantum cryptography from standardization into production reveals a tension between mathematical security and network engineering that algorithm selection alone cannot resolve. The following analysis examines this tension at three levels: transport performance, Zero Trust identity infrastructure, and proposed architectural response.

3.1 The Performance Penalty: Security vs. Latency

The introduction of ML-KEM and ML-DSA into cloud protocol stacks increases key and signature sizes relative to classical alternatives. ML-KEM-768 uses a 1,184-byte encapsulation key; ML-KEM-1024 uses a 1,568-byte key; ML-DSA signatures range from 2,420 to 4,627 bytes [12, 13]. These figures must be evaluated in the context of the full protocol stack rather than in isolation.

Within a TLS 1.3 handshake, encapsulation keys and signatures are carried alongside certificate chains, protocol headers, and record-layer framing. ML-KEM-768 keys can fit within a single standard Ethernet frame; ML-KEM-1024 keys and ML-DSA signatures cannot, in most configurations, without packet splitting or path MTU adjustment. The IETF TLS working group recognizes this and has defined explicit mechanisms, such as record splitting and hybrid key exchange, to manage handshake size during the transition [10]. These mechanisms are available to implementers today and should be treated as part of the migration toolkit rather than as evidence that PQC is broadly incompatible with existing transport infrastructure.

For latency-sensitive environments such as distributed microservice meshes or financial transaction APIs, even well-managed fragmentation introduces a measurable cost: additional round trips, re-transmission risk under congestion, and increased buffer pressure. The severity of these effects varies by path MTU, congestion profile, and record-splitting configuration; variables that differ across cloud providers and network topologies. Quantifying this overhead for specific production environments is a necessary complement to this conceptual analysis and is identified as future work in Section 4.

3.2 The Zero Trust Identity Crisis

Zero Trust Architecture, as defined by NIST SP 800-207, grounds security in continuous, explicit identity verification rather than network perimeter assumptions [15]. PQC migration creates a specific challenge for ZTA: the architecture demands frequent, low-latency identity checks, while the hardware on which identity assertions are anchored cannot be upgraded at the pace of software-defined systems.

ML-DSA signature sizes (2,420 - 4,627 bytes) exceed the volatile memory or transmission capacity of many deployed hardware tokens and legacy HSMs [13]. This means the identity layer, which is the foundation of any ZTA deployment, may remain classically vulnerable even after application-layer migration is complete. An adversary who captures classically protected authentication traffic today and later obtains quantum computing resources may be able to decrypt historical identity assertions or recover sensitive authentication metadata, undermining long-term confidence in archived audit records.

This is not an edge case. HNDL exposure applies to any long-lived credential or key material transmitted in classically encrypted form before the identity infrastructure completes its PQC migration. The asymmetry between software update cycles and hardware procurement cycles means this exposure window will persist for years in most enterprise environments [7, 9].

NIST SP 800-227 is explicit on this point: a KEM or signature scheme can be theoretically secure and still fail in deployment if implementation or operational practices are inadequate [16]. The Zero Trust identity problem is precisely this failure mode: theoretical post-quantum security at the algorithm level does not translate to practical security if the hardware anchoring identity assertions cannot process or transmit the new primitives.

3.3 A Proposed Model: Tiered Cryptographic Agility

A uniform PQC mandate across all cloud layers is operationally impractical in the near term. The network and hardware constraints described above are not uniform across workload types: cold storage is latency-insensitive, microservices are latency-critical, and identity infrastructure is hardware-constrained. A workload-stratified approach can allocate cryptographic overhead to the tiers that can absorb it while reducing HNDL exposure across all tiers.

This paper proposes a Tiered Cryptographic Agility Model that categorizes cloud workloads across three dimensions: latency sensitivity, HNDL exposure, and hardware constraint. Each tier receives a distinct cryptographic strategy calibrated to its operational profile.

- **Tier 1: Cold Storage & Long-Term Data**

Archival data (compliance records, medical repositories, financial contracts) presents the highest HNDL exposure and the lowest latency sensitivity. Because this data retains value over multi-decade horizons, it is a primary target for HNDL collection. Latency and packet size are operationally irrelevant for data at rest, making this tier the most tractable to harden.

The recommended strategy is dual-wrap hybrid encryption: an AES-256 symmetric key is generated for bulk data encryption, and that key is encapsulated using both ML-KEM (per FIPS 203) and a classical ECDH-based mechanism. Both encapsulations are stored with the data. Security is preserved as long as at least one wrapping layer remains uncompromised, consistent with the hybrid model described in the transition literature [7, 8].

- **Tier 2: Real-Time In-Transit Data & Microservices**

Internal microservices and streaming APIs require sub-millisecond handshake performance and cannot absorb the fragmentation costs associated with full ML-KEM or ML-DSA exchanges on every session. At the same time, purely classical key exchange leaves harvested traffic exposed to future quantum decryption.

The proposed strategy for this tier is a pre-shared-key-boosted (PSK) hybrid exchange with frequent symmetric key rotation. Sessions are initialized using a quantum-resistant pre-shared key established out-of-band, for example, during a prior ML-KEM exchange at session setup per [10], so that per-request exchanges use only compact symmetric material. AES-256 keys are then rotated at policy-defined intervals to limit the cryptographic blast radius of any single compromised session.

The rotation interval is a policy variable, not a cryptographically derived constant.

Appropriate values depend on session volume, data classification, and the threat model for a given workload. Deriving defensible interval bounds requires a formal key schedule and state-compromise analysis that models the trade-off between re-key overhead and the quantity of data at risk per interval. This analysis falls outside the scope of the present conceptual framework and is a prerequisite for production deployment.

- **Tier 3: Hybrid Identity & Control Plane (Authentication/ZTA)**

Until PQC-capable HSMs and hardware security tokens are widely available, the identity layer cannot complete a full hardware migration. The proposed bridge strategy uses short-lived, PQC-signed software tokens issued at the gateway and control-plane level to extend quantum resistance into the identity layer without requiring immediate hardware replacement.

The token model maps onto the NIST SP 800-207 ZTA reference architecture [15], which separates the Policy Engine (which evaluates identity and access decisions), the Policy Administrator (which issues tokens), and the Policy Enforcement Point (which validates them at the resource boundary). In this tier, the Policy Administrator issues short-lived tokens, formatted as CBOR Web Tokens (CWT) or JSON Web Tokens (JWT), signed using ML-DSA per FIPS 204. Token lifetimes should be set to minutes rather than hours to limit the exposure window if a token is intercepted. Replay resistance is provided by including a nonce or monotonically increasing sequence number in the token claims. Revocation relies primarily on short token lifetimes, supplemented by a lightweight gateway-maintained revocation list for tokens that must be invalidated before expiry.

This arrangement encapsulates legacy hardware authentication within a quantum-resistant software boundary. Hardware tokens and HSMs continue to anchor device identity, but the assertions they generate are re-signed at the gateway using PQC-capable infrastructure before presentation to protected resources. The resulting trust chain provides post-quantum assurance at the software boundary while hardware migration proceeds on its own procurement timeline.

As with Tier 2, this architecture is a conceptual proposal. A complete security analysis would require formal proof of the trust chain, explicit threat modeling of the gateway as a trust boundary, and evaluation of the token scheme against the full NIST SP 800-207 control set.

Accordingly, the proposed framework should be interpreted as an architectural migration model rather than a production-ready cryptographic protocol specification.

Table 1 synthesizes the operational parameters, cryptographic strategies, and deployment trade-offs across the proposed three-tier framework.

Table 1: The Tiered Cryptographic Agility Matrix

Tier	Focus Area	Cryptographic Strategy	Primary Target	Operational Trade-offs
Tier 1	Cold Storage & Long-Term Data	Dual-wrap hybrid (ML-KEM + AES-256) with classical ECDH backup encapsulation	HNDL mitigation; long-term compliance	Higher computational overhead at write time; acceptable given absence of latency constraints
Tier 2	Real-Time Transit & Microservices	PSK-boosted hybrid exchange with policy-defined AES-256 key rotation	MTU management; HNDL exposure reduction	Elevated key-management complexity; rotation intervals require formal workload-specific derivation
Tier 3	Authentication & Zero Trust Control Plane	Short-lived, ML-DSA-signed CWT/JWT tokens issued at gateway; layered over legacy hardware authentication	Identity protection, hardware lag mitigation	Increased gateway processing load; requires software-defined network control and formal trust chain analysis

4. Limitations

This paper is a conceptual and architectural analysis; several limitations follow from that scope.

First, the operational costs described in Sections 3.1 and 3.2 (fragmentation frequency, latency amplification, HSM memory pressure) are characterized qualitatively from standards documents and published literature. Production-environment benchmarks comparing PQC-enabled and classical protocol stacks in specific cloud configurations are needed to validate and calibrate these characterizations.

Second, the key rotation interval proposed for Tier 2 is a policy variable without a derived bound. A production-grade implementation requires a formal key schedule, a state-compromise model, and throughput analysis under representative load before any interval is set.

Third, the Tier 3 token architecture is a structural proposal, not a formally proven security construction. The trust chain between legacy hardware tokens, the gateway re-signing layer, and protected resources would require formal analysis, including adversary modeling and proof of trust chain integrity, before deployment.

Fourth, this paper focuses on ML-KEM and ML-DSA. SLH-DSA (FIPS 205) is also a finalized NIST standard [14] and may be preferable in contexts requiring hash-based signature security, particularly for long-lived certificate hierarchies. Its integration into the tiered model is not addressed here and warrants separate treatment.

5. Conclusion

Fault-tolerant quantum computing transforms an abstract cryptographic concern into an engineering deadline. HNDL attacks mean that data encrypted today under RSA or ECC may be decryptable once quantum hardware matures, so migration urgency is a function of data longevity as well as algorithm timeline. At the same time, NIST-standardized lattice-based primitives carry payload sizes that existing protocol stacks, HSMs, and hardware tokens were not designed to accommodate.

The Tiered Cryptographic Agility Model proposed here addresses this tension by stratifying cloud workloads according to their operational profiles. Cold storage, where latency is irrelevant and HNDL exposure is highest, receives full hybrid PQC encryption as an immediate priority. Latency-sensitive microservice traffic is protected through quantum-resistant pre-shared key initialization and frequent symmetric key rotation, avoiding per-request PQC overhead. The identity and control plane adopts short-lived, ML-DSA-signed software tokens at the gateway to extend quantum resistance into the identity layer while hardware infrastructure migrates on a longer procurement cycle. Together, these strategies allow organizations to reduce HNDL exposure progressively without requiring simultaneous hardware replacement across the entire stack.

Cryptographic agility, as this framework illustrates, is an architectural property rather than an algorithm property. It depends on decoupling cryptographic primitives from the systems that use them so that standards evolution does not demand infrastructure redesign. Future work should quantify the network and latency overhead of PQC deployment in production cloud environments, derive formal bounds for symmetric key rotation intervals under realistic workload models, and evaluate the Tier 3 token trust chain against the complete NIST SP 800-207 threat model.

References

- [1] Rivest, R. L., Shamir, A., & Adleman, L. (1978). A method for obtaining digital signatures and public-key cryptosystems. *Communications of the ACM*, 21(2), 120–126.
<https://doi.org/10.1145/359340.359342>
- [2] Koblitz, N. (1987). Elliptic curve cryptosystems. *Mathematics of Computation*, 48(177), 203–209.
<https://doi.org/10.1090/S0025-5718-1987-0866109-5>
- [3] Miller, V. S. (1985). Use of elliptic curves in cryptography. In *Advances in Cryptology — CRYPTO '85 Proceedings* (pp. 417–426). Springer Berlin Heidelberg.
https://doi.org/10.1007/3-540-39799-X_31
- [4] National Institute of Standards and Technology (NIST). (2024). *Transition to Post-Quantum Cryptography Standards* (NIST IR 8547). U.S. Department of Commerce.
<https://doi.org/10.6028/NIST.IR.8547.ipd>
- [5] Shor, P. W. (1994). Algorithms for quantum computation: Discrete logarithms and factoring. *Proceedings 35th Annual Symposium on Foundations of Computer Science*, 124–134.
<https://doi.org/10.1109/SFCS.1994.365700>
- [6] Kagai, F., Branch, P., & But, J. (2026). Harvest-Now, Decrypt-Later: A Temporal Cybersecurity Risk in the Quantum Transition. *Journal of Cybersecurity and Privacy*, 6(4), 100.
<https://doi.org/10.3389/fphy.2025.1723966>
- [7] Barker, E., Chen, L., Cooper, D., Moody, D., Regenscheid, A., Souppaya, M., Newhouse, W., Housley, R., Turner, S., Barker, W., & Kent, K. (2025). *Considerations for Achieving Crypto Agility: Strategies and Practices* (NIST Cybersecurity White Paper 39). National Institute of Standards and Technology.
<https://doi.org/10.6028/NIST.CSWP.39>
- [8] Mahendran, A., Kavitha, M. S., Ravi, R., Sekharreddy, B. V., Kumar, M. A., & S., R. (2025). Enhancing Cloud Data Privacy and Integrity Using Post Quantum Cryptographic Algorithms. *Proceedings of the 1st International Conference on Research and Development in Information, Communication, and Computing Technologies (ICRDICCT'25)*, 1, 85–93.
<https://doi.org/10.5220/0013857900004919>
- [9] Birgin, B. (2026). From Policy to Practice: A Sector-Agnostic Operational Framework for Post-Quantum Cryptography Transition. *IEEE Access*.
<https://doi.org/10.1109/ACCESS.2026.11417753>
- [10] Stebila, D., & Thomassen, S. (2026). *ML-KEM Post-Quantum Key Agreement for TLS 1.3 (draft-ietf-tls-mlkem-07)*. Internet Engineering Task Force.
<https://datatracker.ietf.org/doc/draft-ietf-tls-mlkem/>

- [11] Hamburg, M., Hermelink, J., Primas, R., Samardjiska, S., Schamberger, T., Streit, S., Strieder, E., & van Vredendaal, C. (2021). Chosen-ciphertext side-channel attacks on CRYSTALS-Kyber via end-to-end physical evaluations. *IACR Transactions on Cryptographic Hardware and Embedded Systems*, 2021(3), 179–214.
<https://doi.org/10.46586/tches.v2021.i3.179-214>
- [12] National Institute of Standards and Technology. (2024). *Module-Lattice-Based Key-Encapsulation Mechanism Standard* (FIPS 203). U.S. Department of Commerce.
<https://doi.org/10.6028/NIST.FIPS.203>
- [13] National Institute of Standards and Technology. (2024). *Module-Lattice-Based Digital Signature Standard* (FIPS 204). U.S. Department of Commerce.
<https://doi.org/10.6028/NIST.FIPS.204>
- [14] National Institute of Standards and Technology. (2024). *Stateless Hash-Based Digital Signature Standard* (FIPS 205). U.S. Department of Commerce.
<https://doi.org/10.6028/NIST.FIPS.205>
- [15] Rose, S., Borchert, O., Mitchell, S., & Connelly, S. (2020). *Zero Trust Architecture* (NIST SP 800-207). National Institute of Standards and Technology.
<https://doi.org/10.6028/NIST.SP.800-207>
- [16] National Institute of Standards and Technology. (2025). *Recommendations for Key-Encapsulation Mechanisms* (NIST SP 800-227). U.S. Department of Commerce.
<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-227.pdf>
- [17] Hornig, C. (1984). *A Standard for the Transmission of IP Datagrams over Ethernet Networks* (RFC 894). Internet Engineering Task Force.
<https://doi.org/10.17487/RFC0894>